

1/7

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

File No: AI/00394/2023

Subject: Warning

This Agency has become aware through a press publication (<https://www.economiadigital.es/empresas/laliga-reconocimiento-facial-estadios.html>) on October 25, 2023, of news regarding LALIGA conducting a tender for a contract to develop a facial recognition system for fan access to stadiums.

A search on LALIGA's website has confirmed the veracity of the news, as in the section dedicated to LALIGA's tender processes for contracting with suppliers (<https://www.laliga.com/transparencia/gestion-economica/contratacion-proveedores>), it is observed that such a tender process was published on October 17, 2023, under the title "Biometric solutions for facial recognition," with the final date for submission of participation requests being November 2, 2023, and the maximum date for awarding the contract being November 30, 2023.

To this call, only a Contract Base Document is attached, from which it is inferred that the proposals to be submitted by the candidates, who will be pre-selected, must contain an economic offer and a technical proposal for a facial recognition system that complies with the documents that will be provided by LALIGA to the pre-selected candidates at a later stage of the procedure. Specifically, it is mentioned regarding security requirements that bidders must comply with the document "RFP – Biometric solutions for facial recognition Technical Guide," and must provide in the document "Technical Responses – RFP – Facial Recognition Solutions LaLiga" the responses to the different security requirements established in the RFP.

In accordance with the provisions of Article 55 of Regulation (EU) 2016/679, of April 27, 2016, regarding the protection of natural persons with regard to the processing of personal data and the free movement of such data (hereinafter, GDPR), the Spanish Data Protection Agency is competent to perform the functions assigned to it in Article 57, including the enforcement of the Regulation and promoting awareness among controllers and processors regarding their obligations, as well as exercising the powers attributed to it by Article 58.

In this same sense, it is appropriate to cite Article 47 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the guarantee of digital rights (hereinafter, LOPDGDD), according to which, it is the responsibility of the Spanish Data Protection Agency to supervise the application of this organic law and Regulation (EU) 2016/679 and, in particular, to exercise the functions established in Article 57 and the powers provided in Article 58 of the same regulation, in this organic law and its implementing provisions.

2/7

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

In light of the above, it is deemed appropriate to submit this document, which outlines various considerations regarding the data processing intended to be carried out under the aforementioned tender.

**\*\*On Special Category Biometric Data\*\***

According to Article 4.14 of the GDPR, biometric data are defined as: "personal data obtained through

specific technical processing, related to the physical, physiological, or behavioral characteristics of a natural person that allow or confirm the unique identification of that person, such as facial images or fingerprint data.”

The biometric data that will be processed fall within the special category of personal data, the processing of which is initially prohibited by Article 9.1 of the GDPR, when they are: “biometric data aimed at uniquely identifying a natural person.”

Furthermore, Recital 51 of the GDPR states that the processing of biometric data for unequivocal identification in accordance with Article 9.1 of the GDPR includes both identification and authentication procedures:

“The processing of photographs should not systematically be considered as processing of special categories of personal data, as they are only included in the definition of biometric data when the fact that they are processed by specific technical means allows for the unequivocal identification or authentication of a natural person. Such personal data should not be processed unless their processing is permitted in specific situations contemplated in this Regulation, ...”

Whether for identification or authentication, the processing of a biometric personal data is being carried out through which a natural person is uniquely identified. The focus is not on the purpose for which the biometric personal data is processed, but on the fact that through this processing, it is known that this biometric data belongs to a specific natural person.

In this same vein, the Guidelines 05/2022 of the European Data Protection Board (EDPB) on the use of facial recognition in the context of law enforcement interpret the prohibition established in Article 9.1 of the GDPR by stating unequivocally that, although the functions of authentication and identification are distinct, both constitute processing of special category data.

It must be taken into account that the approval of the GDPR has represented a paradigm shift in the field of personal data protection aimed at guaranteeing citizens control over their personal data, establishing high protection standards adapted to the digital environment in which we live. In accordance with the Principle of Proactive Accountability, which inspires the new regulation, the new GDPR emphasizes that the data controller must seriously assess the risks of the processing they wish to establish concerning the rights and...

3/7

C/ Jorge Juan, 6

[www.aepd.es](http://www.aepd.es)

28001 – Madrid

[sedeagpd.gob.es](http://sedeagpd.gob.es)

freedoms of the data subjects, from privacy by design, to identify them, determine the likelihood of materialization and its impact, and foresee measures and guarantees that eliminate or, at least, mitigate the detected risks, preventing their materialization.

This paradigm shift particularly affects the processing of biometric data aimed at identifying or verifying the identity of individuals, which—unlike what occurred under the regime prior to the GDPR—are now considered special category data under Article 9, the processing of which is generally prohibited unless one of the exceptions provided for in Article 9.2 of the GDPR applies.

In this regard, it should be emphasized that the classification as special category data necessarily implies the observance of special caution when determining whether it is possible to carry out processing of this nature. Thus, the entity intending to implement biometric data systems, in this case, LALIGA, must first analyze the concurrence of the necessary criteria of necessity, appropriateness, suitability, and proportionality of the processing.

Therefore, anyone intending to establish a processing of personal data of this nature must undoubtedly ensure that they surpass what has been termed in jurisprudence as “the triple test of proportionality.” This test must be the starting point of their analysis, as only if these methods surpass the

aforementioned triple test will the fulfillment of other requirements or guarantees be demanded.

As our Constitutional Court has repeatedly maintained, to verify whether a restrictive measure of a fundamental right, such as the present one, passes the proportionality test, it is necessary to ascertain whether it meets the following three requirements or conditions: “whether such a measure is capable of achieving the proposed objective (suitability test); whether, in addition, it is necessary, in the sense that there is no other more moderate measure to achieve such purpose with equal effectiveness (necessity test); and, finally, whether it is balanced or proportionate, as it derives more benefits or advantages for the general interest than harms to other conflicting goods or values (proportionality test in the strict sense).”

Moreover, the proactive responsibility system established by the GDPR, focused on the continuous management of the risks associated with processing from the perspective of data protection by design and by default, reinforces the protection of data subjects concerning their personal data by imposing on data controllers the obligation to analyze what data they process, for what purposes, and what types of processing they carry out, relating the potential risks that the processing entails for the rights and freedoms of individuals and from there, deciding what appropriate technical and organizational measures of all kinds they take and apply to ensure compliance based on the detected and assumed risks.

The data protection impact assessment (hereinafter, DPIA) is the tool that in the GDPR addresses the guarantee of compliance with this.

4/7

C/ Jorge Juan, 6

[www.aepd.es](http://www.aepd.es)

28001 – Madrid

[sedeagpd.gob.es](mailto:sedeagpd.gob.es)

treatment. The risk analysis, the proportionality assessment, the establishment of measures that mitigate the impact, and other previously mentioned requirements are always part of it.

Considering what is established in Article 35, paragraph 1 of the GDPR, “When it is likely that a type of processing, in particular if it uses new technologies, by its nature, scope, context, or purposes, entails a high risk to the rights and freedoms of natural persons, the controller shall carry out, prior to the processing, an assessment of the impact of the processing operations on the protection of personal data...”

As well as the wording of paragraph 4 “...The supervisory authority shall establish and publish a list of the types of processing operations that require an impact assessment regarding data protection in accordance with paragraph 1...”

In compliance with this mandate, the AEPD has published on its website a list of types of data processing that require an impact assessment regarding data protection. There is no doubt about the high-risk nature of this data, given the fulfillment of the criteria corresponding to numbers 4, 5, and 10 (those involving the use of special categories of data; the use of biometric data and those involving the use of new technologies or an innovative use of established technologies) of the document “Lists of types of data processing that require an impact assessment regarding data protection,” made public by the AEPD in development of the provision contemplated in paragraph four of the aforementioned Article 35.

Therefore, there is no doubt that the processing of biometric data must be preceded by a valid impact assessment, which includes at least the sections provided for in Article 35.7 of the GDPR. This implies that it is not enough to carry out a DPIA; it must be successfully completed for the processing to be lawful and legally admissible.

As stated in the Guide recently published by the AEPD on its website

(<https://www.aepd.es/documento/guia-control-presencia-biometrico-nov-2023.pdf>), the successful

completion of a DPIA requires demonstrating the suitability, necessity, and proportionality of the processing and managing the specific risks of the processing from the design stage, with the practical application of measures aimed at them in such a way that an acceptable risk threshold is guaranteed throughout the entire lifecycle of the processing, as established in Article 35 of the GDPR. Furthermore, it requires prior consultation with the supervisory authority in cases where the controller has not taken measures to mitigate the risk in accordance with Article 36 of the GDPR.

This assessment will be carried out prior to the commencement of processing, but it should be understood as a continuous or periodic assessment, in the sense established by Article 35.11 of the GDPR, which states: "If necessary, the controller shall examine whether the processing is in compliance with the impact assessment regarding data protection, at least when there is a change in the risk posed by the processing operations."

5/7

C/ Jorge Juan, 6

[www.aepd.es](http://www.aepd.es)

28001 – Madrid

[sedeagpd.gob.es](http://sedeagpd.gob.es)

In accordance with the above and in application of the GDPR, before any system of this nature can be implemented, it is mandatory to conduct a risk analysis and an impact assessment related to data protection aimed at justifying and ensuring compliance with all the principles, obligations, limitations, and rights established in the GDPR and its development.

Among all these requirements, which are mentioned without being exhaustive, special mention should be made of the obligation to carry out and surpass "an assessment of the necessity and proportionality of the processing operations with respect to their purpose," as provided as part of the DPIA in Article 35.7.b) of the GDPR.

Furthermore, it is emphasized that, even if the assessment of the necessity and proportionality of the processing operations with respect to their purpose is surpassed, it will still be necessary, before being able to carry out the processing, to verify that the prohibition on processing special categories of data is lifted because the provisions of Article 9.2 of the GDPR apply to the specific case; that there is an applicable legal basis in accordance with Article 6 of the GDPR, and that, as a whole, it complies with the provisions of personal data protection regulations.

Proposal for Tender by LALIGA

In cases like the one at hand, where LALIGA aims to implement biometric data processing systems following their tender, it must ensure that these systems surpass "the triple test of proportionality" mentioned earlier. As already stated, this test must be the starting point of its analysis, as only if these methods surpass the aforementioned triple test will compliance with other requirements or guarantees be demanded.

This technology can be truly intrusive and requires a calm ethical and legal debate, as it may have very adverse effects on fundamental values and human integrity.

Therefore, it is insisted that, before tendering, and even more so before implementing a fingerprint recognition system, and/or facial recognition or any other system that processes biometric data, the responsible party must first assess whether there is another less intrusive system that achieves the same purpose. Section 73 of the Guidelines 3/2019 of the EDPB, on the processing of personal data through video devices, states that in general: "The use of biometric data and, in particular, facial recognition entails high risks for the rights of the data subjects. It is essential that the use of such technologies occurs while duly respecting the principles of lawfulness, necessity, proportionality, and data minimization as established by the GDPR. Although the use of these technologies may be perceived as particularly effective, data controllers must first evaluate the impact on fundamental rights and freedoms and consider less intrusive means to achieve their legitimate purpose of processing."

In the case examined, taking into account the evidence and data known so far, it can be deduced that the biometric system proposed for accessing football stadiums (especially facial recognition) may be useful for the organization, but is more difficult to justify as necessary from the perspective defined by the GDPR, since this system is not the only one that can achieve the intended purpose. One must not confuse necessity with the convenience of the organization; for example, the hypothetical speed in verification, cost reduction, or adaptation to technological advances are not reasons that justify the necessity of using these systems. These favor the organization and not the fans, and therefore are not subject to analysis when we are assessing whether such an intrusive system on the fundamental right to the protection of personal data is truly necessary or can be avoided.

Indeed, when there are truly equivalent and available options for all fans to access football stadiums that are less intrusive to their rights and freedoms, and allow for the identification-verification of the fans' identity, such as the presentation of the access ticket along with a document proving their identity, it becomes difficult to justify the necessity of implementing more intrusive systems such as biometric processing.

In this context, it is particularly important to clearly define whether it is truly necessary to use biometric methods to ensure the safety of individuals and prevent violence in stadiums.

In summary, if there are truly equivalent and available options for all fans to access the stadiums, it would be when one could understand that consent is the appropriate instrument to validate the system, provided that the requirements of Article 4.11 of the GDPR and the other conditions of Article 7 of the GDPR are met. Moreover, it must be demonstrated that there is an objective necessity and possible alternatives.

At the same time, this implies that if there are available alternatives for all fans to choose less intrusive options for their rights and freedoms at any given time, the processing of biometric data will cease to be necessary for achieving the purpose. Since when the processing is of high risk (as is the case), it must meet the positive necessity assessment (Article 35.7.b). However, it is not only necessary to comply with the positive necessity assessment, but also, after passing the strict proportionality test and the impact assessment, it must also overcome the prohibition of Article 9 of the GDPR for being in one of the situations detailed in paragraph 2 of that article, as well as being subject to one of the lawful bases for processing set out in Article 6 of the aforementioned regulation.

The Regulation reflects in its articles the special impact that the processing of certain personal data has on the fundamental rights and freedoms of individuals, establishing a general prohibition that can only be excepted if one of the circumstances specified in paragraph 2 of Article 9 of the GDPR applies.

Once the prohibition has been lifted, it is necessary to analyze whether the processing in question can be carried out under at least one of the conditions listed in Article 6.1 of the GDPR. That is to say, one should not propose a processing and then seek a lawful basis. On the contrary, there should be a condition defined in Article 6.1 of the GDPR for a controller to decide to carry out processing.

By virtue of all the above, and in application of the powers conferred upon it by Article 58.2.a) of the

GDPR, this Agency issues the following WARNING to LALIGA:

- Prior to any decision to implement a system that involves the processing of biometric data, considering this from the design and by default, it is essential that a risk management (Article 24.1 GDPR) is carried out and, in accordance with the provisions of Article 25 of the GDPR, appropriate technical and organizational measures are applied to ensure and demonstrate that the processing is compliant with the GDPR. In particular, in the case of high risk, it must successfully pass a Data Protection Impact Assessment (DPIA) that includes and also passes the triple test of suitability, necessity, and strict proportionality established in Article 35.7.b and also provided for by the doctrine of the Constitutional Court.

Furthermore, it must be verified that one of the situations provided for in Article 9.2 of the GDPR applies so that the general prohibition on the processing of these personal data does not apply. Finally, it must be analyzed and concluded that the processing can be carried out under one of the lawful bases set out in Article 6 of the GDPR.

Finally, it is noted that, in the event of failing to adopt the measures that may be necessary to align its actions with what is legally established, it could incur a violation within the jurisdiction of this Agency, which could lead to the initiation of preliminary investigation proceedings and/or corrective actions, including sanctions.

1011-240521

Mar España Martí

Director of the Spanish Agency for Data Protection